Questions and Evidence-Based Answers

Anticipatory Argumentation for an Open, Secure and Mission-Aligned University Digital Infrastructure

— Policy-Layer Argumentation Module —

SUIT suite version 1.0.3
Visibility: PUBLIC
Status: Approved by the approving academic units of the institution on *(approval date to be set)*
Based on the SUIT Working Group [1↗]
Print date: November 3, 2026

A systematic, concession-then-rebuttal treatment of the governance and policy objections most likely to be raised against a segmented, federated, mission-aligned architecture

This module is institution-neutral. It defends the policy-layer proposals of the dossier — segmentation, federated governance, research autonomy, BYOD and managed AI access, transferability, incident interpretation, regulatory reading, cost and feasibility, and methodology — without reference to any particular adopting institution. Each answer is built on the five-layer evidence methodology: binding law, normative standards, sector consensus, empirical data, and institutional precedent.

"Freedom in research and training is the fundamental principle of university life, and governments and universities, each as far as in them lies, must ensure respect for this fundamental requirement."

— *Magna Charta Universitatum*, Bologna, 1988 [2↗]

Contents

How to read this module 3

1 Questions on network segmentation 4

2 Questions on governance models 8

3 Questions on research zone autonomy and local administrative privileges 11

4 Questions on BYOD and AI cloud services 14

5 Questions on institutional comparisons and transferability 17

6 Questions on the independent adjustments commission 20

7 Questions prompted by recent incidents 23

8 Questions on regulatory interpretation 25

9 Questions on costs and feasibility 30

10 Questions on methodology, process and credibility 34

11 Summary: quick-reference table 36

12 Summary and outlook 40

References 41

How to read this module

This module anticipates the objections most frequently raised against the policy-layer proposals of the dossier and answers each on the evidence. Three box types structure every exchange:

Question a good-faith technical or governance objection, reformulated at its strongest before it is answered.

Insidious framing an objection that smuggles in a premise, a motive, or a rhetorical trap; the answer addresses the framing, not only the surface claim.

Answer an evidence-based response following the concession-then-rebuttal pattern: partial merit is conceded honestly, then the objection is answered across independent evidence layers.

Evidence methodology. Every substantive answer is built from up to five independent layers, presented strongest-first and cross-corroborated:

1. **Legal** — binding instruments of the adopter's jurisdiction; in EU/CoE editions these are the EU Charter, European Court of Human Rights (ECtHR) and Court of Justice of the European Union (CJEU) case law, General Data Protection Regulation (GDPR), NIS2 Directive (NIS2) and the European AI Act (AI Act), used here as the worked example;
2. **Standards** — normative frameworks (NIST CSF 2.0, NIST SP 800 series, ISO/IEC 27001, Control Objectives for Information and Related Technologies (COBIT) 2019);
3. **Sector** — consensus of professional bodies and surveys (EDUCAUSE, GEANT pan-European research network (GEANT), Verizon DBIR, Sophos);
4. **Empirical** — quantified measurements and incident root-cause analysis;
5. **Institutional** — named universities and research organisations with publicly documented practice.

A thesis is treated as robust only when at least three layers sustain it independently; where a layer is contestable, the answer says so. The institutional precedents named below (MIT, Stanford, Oxford, ETH Zürich, CERN, Michigan, and others) are cited as *evidence*, not as models any particular institution must replicate.

1 Questions on network segmentation

> "For every complex problem there is an answer that is neat, simple, and wrong."
>
> — H. L. Mencken, *Prejudices: Second Series*, 1920

Q1.1 — "Segmentation increases complexity and therefore the attack surface"

Network segmentation multiplies the number of zones, inter-zone boundaries, and firewall rules. More boundaries mean more configuration points, more potential misconfigurations, and therefore a *larger* attack surface. A single, well-managed perimeter is simpler and therefore safer.

Answer to Q1.1

Partial merit acknowledged: segmentation does increase *configuration complexity*. This is a genuine engineering concern, not a straw-man.

However, the question conflates two distinct concepts:

1. *Configuration complexity* (the number of rules to manage) and
2. *Attack surface* (the set of points an attacker can exploit).

Segmentation *increases* the former but *decreases* the latter. NIST SP 800-53 Rev. 5 [3↗] explicitly recommends "protecting internal boundaries and isolating components to reduce the attack surface and limit damage." The NIST Cybersecurity Framework 2.0 [4↗] and ISO 27001:2022 control A.8.22 [5↗] both mandate network segregation precisely because it *reduces* the blast radius of any single compromise.

Empirical evidence: documented university ransomware failures of 2024–2025 demonstrate that *centralised, unsegmented perimeters amplify damage*. Where an institution runs a single large administrative perimeter, an attack can disrupt the entire institution for an extended period; conversely, a segmented architecture is designed to confine a breach to a single subnet, limiting the blast radius that a flat network exposes [6↗]. The Verizon 2024 DBIR [7↗] documents the prevalence of lateral movement in such breaches — the propagation path that segmentation, per the NIST and ISO controls cited above, is designed to interrupt.

Managing the configuration complexity: the dossier's phased transition addresses this directly — governance and charters first, a pilot on selected entities next, then gradual extension. Software-Defined Networking (SDN) tools and infrastructure-as-code automate rule management and reduce human error. The complexity argument is an argument for *proper tooling and gradual rollout*, not for avoiding segmentation.

Q1.2 — "A single perimeter is easier to monitor and defend"

With all traffic passing through a single firewall, the security team has full visibility. Segmentation creates blind spots between zones.

Answer to Q1.2

This argument assumes that *centralised inspection* equals *comprehensive visibility*. The opposite is frequently true in practice:

- A single perimeter firewall handling research traffic at 10–100 Gbps cannot perform deep packet inspection without creating bottlenecks — a documented case measured a **five- to twelve-fold throughput degradation** when research traffic traversed an enterprise firewall [8↗].
- When performance degrades, researchers route around the firewall (Shadow IT), creating *actual* blind spots far worse than managed inter-zone boundaries.
- In a segmented architecture, each zone has *its own* monitoring (a Zeek Intrusion Detection System (IDS) on the Science Demilitarised Zone (Science DMZ), IDS/Intrusion Prevention System (IPS) on the administrative zone, per-zone logging baselines). Total observability is *greater*, not lesser.

CERN explicitly operates zone-specific monitoring alongside backbone monitoring [9↗]. The University of Michigan deploys per-zone security classifications and dedicated sensitive-data environments [10↗]. These institutions have demonstrably *better* visibility than a single-perimeter model, not worse.

Q1.3 — "You just want less security to make researchers' lives easier"

The real motivation behind this document is not improved security but reduced control. Researchers want to do whatever they want without oversight. This is a *comfort* argument dressed up in security language.

Answer to Q1.3

The validity of a proposal is best assessed on its evidence and logic, independently of the motives attributed to its authors — attacking the imputed motive rather than the argument is an *ad hominem*. The proposals must be evaluated on their *substance*.

On the substance: the dossier proposes *more* security for sensitive data, not less. The administrative enclave is *smaller, easier to harden and easier to monitor*. The security function gains:

- A reduced and well-defined perimeter for the most sensitive assets;
- Charters replacing informal exceptions with accountable, auditable autonomy;
- Zone-specific monitoring replacing a single, overwhelmed checkpoint;
- Evidence production for GDPR Article 32 and NIS2 compliance.

The "comfort" framing is refuted by the proposal's own evidence: the design is endorsed by NIST [3↗, 4↗], ISO 27001 [5↗], and EDUCAUSE [11↗], and is practiced by MIT, Stanford, Oxford, ETH Zürich, CERN, and the 100-plus universities operating a Science DMZ [12↗, 13↗]. If "wanting less security" were the true motive, these institutions and frameworks would not converge on the same model.

Constructive engagement with evidence-based proposals, as recommended by the COBIT 2019 process EDM05 (*Ensured Stakeholder Engagement*), is more productive than debating mo-

tives [14↗].

Q1.4 — "The analogy with firebreaks is misleading — a forest is not a network"

The argument for segmentation leans on a forestry analogy (firebreaks). But networks are not forests: a misconfigured inter-zone rule *is* a vulnerability, unlike a physical firebreak.

Answer to Q1.4

Partial merit: all analogies have limits, and pushing any metaphor too far weakens the argument. The firebreak analogy illustrates one principle only: *compartmentalisation limits propagation*. It is not a complete model of network security.

However, the principle itself does not depend on the analogy. It is established by:

- NIST SP 800-207 (Zero Trust architecture (Zero Trust) Architecture) [15↗]: "assume breach, limit blast radius";
- NIST SP 800-53 Rev. 5 [3↗]: "isolate components to reduce attack surface";
- The Verizon 2024 DBIR [7↗]: credential abuse and ransomware dominate the measured breach patterns — the in-network progression that segmentation (per the NIST controls above) is designed to interrupt.

The risk of misconfigured rules is real but is an *implementation risk*, not an argument against the principle. The phased transition (pilot first, then rollout) and use of SDN automation directly mitigate this risk.

Technical implementation: the segmentation contract, zone catalogue, and migration approach are developed in the standalone Technical Reference [16↗].

Q1.5 — "You claim Zero Trust but exclude SASE/ZTNA and never map to NIST SP 800-207"

You claim a Zero-Trust posture, yet you exclude SASE and ZTNA — the two products the market equates with Zero Trust — and never demonstrate Zero-Trust maturity against the actual standard, NIST SP 800-207.

Answer to Q1.5

Excluding SASE/ZTNA from the structural foundation is a sovereignty choice, not a rejection of Zero Trust — and the architecture maps directly to NIST SP 800-207 [15↗]. SASE and ZTNA are commercial *packagings* of Zero-Trust ideas in which a supplier operates the data plane and terminates TLS; that is precisely the data- and technical-sovereignty loss the dossier argues against. Zero Trust is a set of principles, not a product, and the reference architecture realises them structurally:

1. **Resources, secured everywhere** (Tenets 1–2): every layer is a protected resource and communication is secured regardless of network location.
2. **Identity-based, per-session access** (Tenets 3, 6): access is mediated by federated

identity (Single Sign-On (SSO)-capable identity providers, eduGAIN) and authorised per session, strictly enforced before access.

3. **Dynamic policy** (Tenet 4): the policy plane decides on identity, role, posture and environment; zones default-deny.
4. **Posture and monitoring** (Tenet 5): endpoint posture signals and the observability layer continuously measure asset integrity.
5. **Telemetry to improve posture** (Tenet 7): an event pipeline collects decision and access telemetry used to refine policy.

The architecture therefore adopts Zero Trust *by SP 800-207 tenet*, while declining the SASE/ZTNA *deployment model* whose supplier-operated data plane is incompatible with the institution's sovereignty objectives. SASE may still be adopted tactically where sovereignty is not at stake; it is not the structural foundation.

2 Questions on governance models

> "The price of freedom is eternal vigilance."
>
> — Attributed to Thomas Jefferson

Q2.1 — "Federated governance creates accountability gaps — who is responsible when a breach occurs?"

If departments manage their own zones, the security function cannot be held responsible for their failures. Accountability becomes diffuse and no one is truly in charge.

Answer to Q2.1

This is a genuine concern and the dossier addresses it explicitly through **enclave charters** modelled on Oxford [17↗] and ETH Zürich [18↗]:

1. Each zone has an *identified owner* (unit head or delegate);
2. The charter specifies incident contacts, logging baselines, and minimum security standards;
3. The central security function defines the *standards* and operates the Security Operations Centre (SOC); departments *implement* within their perimeter;
4. This is not *less* accountability but *more granular* accountability — a model where one officer is nominally responsible for everything but cannot actually control departmental behaviour creates the *real* accountability gap.

At Oxford, unit heads are explicitly *accountable* for information security in their area [17↗]. At Michigan, an IT Council coordinates across nineteen schools with clear responsibility lines [19↗]. At ETH Zürich, the Administrator Rights Agreement [20↗] is a binding *transfer* of responsibility, not an abdication.

Key point: the question is not "centralised vs. distributed accountability" but "formal accountability vs. informal unaccountability." The situation in which users run shadow IT with zero accountability is the real governance failure.

Live-incident containment authority: accountability includes the power to act during an active breach. The enclave charter pre-grants the central security function a scoped, auditable, time-bounded *emergency containment authority* — the right to force network isolation or quarantine of a zone on defined incident criteria, logged and reviewed post-hoc by the digital-policy commission — overriding zone autonomy in real time. This is not an erosion of the federated model but its safeguard: NIS2 Art. 21 (technical and operational risk-management measures) and Art. 23 (incident-reporting duty) already vest a central duty to contain; NIST CSF 2.0 Respond and ISO/IEC 27035 standardise the containment workflow; and the Oxford and ETH Zürich unit-head models already subordinate the unit to a central isolation decision [17↗, 18↗]. The authority is operationalised in the Wave 7 audit-and-incident-response runbooks of the Technical Reference, not merely asserted here.

Q2.2 — "Departments will treat autonomy as the absence of responsibility"

Giving departments autonomy over their IT will lead to neglect: unpatched servers, exposed databases, abandoned research machines connected to the network.

Answer to Q2.2

This risk is real and is identified in the dossier's risk register (rated Medium probability / High impact).

Mitigations are built into the proposal:

- **Charters with accountability:** mandatory incident contacts, logging baseline, periodic reviews;
- **Baseline monitoring by the SOC:** the central security team monitors all zones for anomalies, including research zones;
- **Default-deny at internal boundaries:** designed to contain a neglected zone's incident within that zone, subject to tested boundaries and documented exceptions;
- **ETH Zürich isolation model:** non-compliant resources are placed in isolated network zones [18↗] so that weaknesses are not exploitable from outside;
- **Periodic audits:** a digital-policy governance body reviews zone compliance.

Counter-question: under the current monolithic model, are departmental "servers under desks" patched, monitored, and accountable? The answer is typically *no* — they exist as shadow IT with *zero* oversight. Formalised autonomy with charters is strictly *better* than informal unmanaged autonomy.

Q2.3 — "This proposal undermines the security function's authority"

By proposing that academic representatives sit on a digital-policy commission, and that an independent commission can override IT policy decisions, the proposal effectively strips the security function of the authority needed to protect the institution.

Answer to Q2.3

This question rests on a distinction that governance frameworks draw explicitly. The proposal does not remove the security function's authority — it *positions it correctly* within a governance structure. There is a fundamental distinction between:
Governance: strategic direction and risk appetite (the digital-policy commission);
Management: operational execution (the security function and IT department).
This distinction is foundational in COBIT 2019 [14↗] and in the work of Weill and Ross [21↗] on IT governance. De Haes and Van Grembergen [22↗] explicitly warn against conflating governance with management: the security function *executes* security policy; the governance body *defines* the risk appetite and resolves conflicts between security and the institutional mission.

No security officer at MIT, Stanford, Oxford, Michigan, or ETH Zürich has *unilateral* authority over all IT decisions [17↗, 19↗]. In all these institutions, governance bodies with academic representation define policy, and the security function implements it. This is not a

diminishment — it is professional governance.

The real question: should a single operational officer have the authority to make decisions affecting academic freedom, research competitiveness, and the fundamental rights of employees *without external oversight*? Every governance framework says no.

Q2.4 — "Academics should not interfere with security — they lack expertise"

Security is a technical discipline. Putting academics on a digital-policy commission is like putting passengers in the cockpit.

Answer to Q2.4

A more precise analogy might be surgeons having input on hospital operating-theatre design — academics are *the people whose work the infrastructure exists to serve*, not passive passengers. No hospital would exclude surgeons from that process and defer entirely to the facilities manager.

The expertise argument conflates two levels:

- *Technical implementation* (firewall rules, IDS configuration): this is the security function's domain — no one disputes this;
- *Policy direction* (what should be restricted, what autonomy is needed, what risk appetite is acceptable): this is a *governance* question requiring input from all stakeholders.

NIST CSF 2.0 Govern (GV) function [4↗] explicitly integrates "stakeholder needs" into cybersecurity strategy. ISO 27001 Clause 4.2 [5↗] requires understanding "the needs and expectations of interested parties." EDUCAUSE [23↗] recommends governance structures including academic representation. Excluding the primary users of the infrastructure from governance decisions violates every major IT governance framework.

Furthermore, in a university context, many academics *are* technical experts: computer-science researchers, cybersecurity specialists, network engineers. Dismissing their expertise because they are "academics" is a category error.

3 Questions on research zone autonomy and local administrative privileges

> "Discovery consists in seeing what everybody else has seen and thinking what nobody has thought."
>
> — Attributed to Erwin Schrödinger

Q3.1 — "Giving researchers root access creates unacceptable risk"

Root access means researchers can disable security tools, install vulnerable software, and create backdoors. One compromised research machine can become a launchpad for attacks against the entire institution.

Answer to Q3.1

Partial merit: root access is indeed a powerful privilege that can be misused. This is why the dossier does not propose *unrestricted* root access but *accountable* root access within dedicated zones.

The ETH Zürich model [20↗]:

1. The user requests root rights for a documented purpose (thesis, research project);
2. By signing the agreement, the user accepts *personal responsibility* for maintenance;
3. The user commits not to disable basic security mechanisms (logs, updates);
4. Non-compliant machines are placed in isolated network zones [18↗];
5. It is a *transfer of responsibility*, not an abdication of control.

Why this is safer than the alternative: when root access is denied, researchers jailbreak managed machines, use hidden VMs, connect lab equipment via personal hotspots, or deploy entirely unmanaged servers under desks. These shadow systems have *no* logging, *no* patching, *no* accountability, and *no* isolation. Formal root access with charters, accountability, and network isolation is strictly safer than informal root access with no controls.

The "launchpad" fear: in a segmented architecture, the boundaries are designed to contain a compromised research machine within its context, subject to tested boundaries and documented exceptions, so that it does not reach the administrative enclave — this is the entire point of segmentation. At CERN, experiment networks are isolated from the general network by strict firewalls and Access Control List (ACL)s [24↗], yet physicists retain extensive local control.

Q3.2 — "Researcher autonomy = researcher liability — this unfairly burdens academics"

By transferring responsibility via charters, the institution offloads security risk onto academics who are not trained for it. This is unfair and possibly illegal under employment law.

Answer to Q3.2

This concern has merit when pushed to extremes — researchers should not be expected to be full-time system administrators. The dossier addresses this through multiple mechanisms:

- Central IT still provides the backbone, Identity and Access Management (IAM), SOC, and baseline monitoring — researchers are not "on their own";
- ETH Zürich deploys *Data Stewards* [25↗] and departmental IT staff (ISGs) [26↗] who bridge the gap between central IT and researchers;
- The charter defines *proportionate* responsibilities: a researcher who installs a notebook server has lighter obligations than one running a public-facing web service;
- The progressive transition includes training of local IT correspondents by the IT services.

On the legal point: the charter model is an established, documented practice at institutions such as ETH Zürich and Oxford [17↗, 20↗]. The responsibility is *contractual and proportionate*, not a blanket transfer of institutional liability.

Counter-question: under the current model, when a researcher deploys shadow IT that is breached, who is liable? The answer is unclear — which is precisely the governance failure that charters resolve.

Q3.3 — "The Science DMZ bypasses security controls — this is a security hole by design"

The Science DMZ explicitly removes the enterprise firewall from the research data path. This means research traffic is not inspected. This is an indefensible gap in security posture.

Answer to Q3.3

The premise is factually incorrect. The Science DMZ does *not* remove security — it replaces one type of security (a stateful firewall, designed for enterprise traffic) with another appropriate for research traffic:

ACLs on routers: whitelist-based filtering at line speed;

Zeek (formerly Bro) IDS: a dedicated intrusion-detection system monitoring all Science DMZ traffic [27↗];

perfSONAR: active performance monitoring that detects anomalies [28↗];

Data Transfer Node (DTN) hardening: Data Transfer Nodes are purpose-built, minimal-service machines with a reduced attack surface.

This model was developed by ESnet [29↗], the U.S. Department of Energy's network serving nuclear laboratories. It is deployed at **over 100 universities** through NSF funding [12↗, 13↗]. If bypassing the enterprise firewall were a "security hole by design," neither the DoE nor the NSF — both security-conscious organisations — would have funded and promoted it.

The deeper point: a stateful firewall that, in a documented case, mishandled TCP window scaling on high-volume long-distance flows and degraded research throughput by **five- to twelve-fold** [8↗] does not *provide* security. It provides the *appearance* of security while driving researchers to bypass it via shadow IT. A Science DMZ with ACLs, IDS, and monitoring provides *actual* security appropriate to the traffic profile.

© SUITOAAD

Q3.4 — "If the Science DMZ were so good, our network operator would already have deployed it"

The model is presented as state of the art and adopted by 100-plus universities. Yet neither our national research network nor our HPC team publishes any Science DMZ today. The absence is itself an argument: if it were the right answer for us, our National Research and Education Network (NREN) or our High-Performance Computing (HPC) team would already have built it.

Answer to Q3.4

The factual premise may be correct; the inference is not — this is an appeal to absence. That an institution or its NREN has not yet deployed a pattern is not evidence that the pattern is unsuitable; it is, in most cases, evidence about *capacity and funding routes*.

Three observations frame the diagnostic generically:

1. **The substrate is often already present.** High-bandwidth NREN access (e.g. via GEANT [30↗]), a national Computer Security Incident Response Team (CSIRT) for incident response, and an HPC facility moving large volumes of data internationally are frequently in place. What is missing is the architectural *pattern*, not the bandwidth. Current research transfer over generic enterprise paths (`rsync`, `scp`) is an enterprise-IT profile, not a research-tuned one [29↗, 31↗].
2. **Non-deployment tracks capacity, not merit.** A small research ecosystem with a limited pool of research-network engineers, and the absence of a dedicated funding programme equivalent to the NSF CC* line that explicitly funded Science DMZs at over 100 U.S. campuses [12↗, 13↗], explains non-deployment without implying technical inadequacy.
3. **Convergent practice elsewhere is overwhelming.** ESnet, NSF, GEANT, and the Medical Science DMZ pattern — documented in implemented deployments at major U.S. biomedical-research institutions [32↗] — converge on the design. "We have not done X yet" is a weak argument against X when every comparable research ecosystem has.

The realistic form is mutualised. The proposal is not a siloed institution-only Science DMZ but a federated research-network zone — with a Medical Science DMZ enclave for biomedical workloads — *co-designed* across the research-active institutions and the NREN. Mutualisation is the form in which the operational and economic case closes at small scale.

One honest caveat. A 2024 quantitative study confirms that Science DMZ benefits are not automatic: without deliberate tuning of hosts, protocol stacks and measurement, latency on long-RTT paths can even degrade [33↗]. This argues for operational ownership and tuning, not for inaction.

4 Questions on BYOD and AI cloud services

> "The best way to predict the future is to invent it."
>
> — Alan Kay, Xerox PARC, 1971

Q4.1 — "BYOD is inherently insecure — personal devices cannot be trusted"

Personal devices are not managed, may be infected, may lack encryption, and may be shared with family members. Allowing them on the network is an unnecessary risk.

Answer to Q4.1

Bring Your Own Device (BYOD) is not a policy choice — it is a reality. Faculty members use personal laptops. Researchers use personal phones. Visiting scholars arrive with their own devices. The question is not whether BYOD exists but whether it is *managed or unmanaged*.

The dossier proposes *progressive interoperability*:

1. **Without authentication:** Internet only (guest zone);
2. **With Multi-Factor Authentication (MFA) authentication:** access to teaching and research resources matching the user's profile;
3. **With a compliant device (verified posture):** extended access including administrative resources via a secure Virtual Desktop Infrastructure (VDI).

This is precisely the Zero Trust approach recommended by NIST SP 800-207 [15↗]: access decisions based on identity and device posture, not on whether the device is "managed" or "personal."

Education Roaming (eduroam) [34↗] — the global academic federated Wi-Fi system — has operated successfully for two decades on exactly this principle: authenticate users, not devices.

The alternative — banning BYOD — pushes devices onto personal hotspots and creates genuinely unmanaged, invisible connections. This is *less* secure than a dedicated BYOD subnet with progressive access.

Q4.2 — "Giving researchers free access to non-EU AI cloud services creates GDPR liability"

Commercial AI cloud services are not fully GDPR-compliant. If researchers send personal data to these services, the institution faces regulatory sanctions.

Answer to Q4.2

This is a legitimate concern and the dossier does not propose unfettered access without safeguards. It proposes a *differentiated framework*:

1. **Data classification:** personal data is *never* sent to a third-country service without a

lawful basis and a valid transfer mechanism — an adequacy route where one exists (e.g. the EU–US Data Privacy Framework for certified providers), or standard contractual clauses (Standard Contractual Clauses (SCC)s) supplemented, per *Schrems II*, by a documented Transfer Impact Assessment (Transfer Impact Assessment (TIA)) and supplementary technical measures (encryption, pseudonymisation, key custody), as operationalised in the regulatory mapping;

2. **Environment separation:** research AI environments are isolated from the administrative zone, preventing accidental mixing of personal data with research API calls;
3. **AI Act risk-based compliance:** for researchers *using* commercial AI services, the applicable framework is the AI Act's risk-based classification — *not* a blanket research exemption; the Art. 2(6)/2(8) exemptions cover bespoke, pre-market research tools, not commercial-API use [35↗];
4. **Traceability:** logging of external API access for auditing;
5. **Training:** researcher awareness of GDPR implications.

The alternative is worse: when access is blocked, researchers use personal accounts on personal devices outside the institutional network, sending the same data with *zero* institutional safeguards, *zero* SCCs, and *zero* traceability. The institution's GDPR exposure is *higher*, not lower, when it refuses to provide a managed pathway.

Competitive reality: leading research universities increasingly provide researchers with *managed* access to global AI platforms rather than prohibiting them outright. An institution that blocks such access risks putting its researchers at a competitive disadvantage relative to peers who provide a governed pathway.

Q4.3 — "The AI access proposal is about convenience, not necessity"

Researchers managed perfectly well before generative AI. AI cloud access is a luxury, not a structural need for research. The institution should not compromise its security posture for fashionable tools.

Answer to Q4.3

This perspective may underestimate the pace of change in research methodologies. Behavioural research on decision-making [36↗] documents *status-quo bias*: the tendency to prefer the current state of affairs simply because it is familiar, regardless of evolving evidence.

On the facts: foundation models and generative AI are *not* optional luxuries for research in computer science, NLP, machine learning, data science, computational biology, digital humanities, and increasingly the social sciences. Major conferences (NeurIPS, ICML, ACL, CVPR) increasingly feature work relying on cloud AI platforms, and funding agencies explicitly fund AI-based research.

Dismissing AI as "fashionable tools" is analogous to dismissing the Internet in 1995 or statistical software in 1985. The question is not *whether* universities will use AI cloud services but *whether they will do so through managed, secure channels or through ungoverned shadow IT*.

Structural need: AI research *requires* access to APIs (for model comparison, fine-tuning, evaluation), cloud accelerators (for training), and open-source model repositories. These are not interchangeable with local-only tools. Teaching advanced AI courses without API access is like teaching chemistry without a laboratory. The differentiating factor is not the tool but the *governed workflow*: managed access with classification and logging improves outcomes, while a blanket ban displaces the same activity into the ungoverned shadow.

© SUITOAAD

5 Questions on institutional comparisons and transferability

"In theory, there is no difference between theory and practice. In practice, there is."

— Attributed to Yogi Berra

Q5.1 — "You are comparing us to MIT and Stanford — this is absurd"

MIT has a multi-billion endowment; Stanford has thousands of IT staff. We are a small institution. These comparisons are meaningless and the models cannot transfer.

Answer to Q5.1

The comparison is not about replicating budgets but about adopting scale-independent architectural principles. The question assumes that the only relevant difference is scale, and that smaller institutions cannot adopt principles from larger ones — a *false equivalence* between "adopting a principle" and "replicating a budget".

The dossier does not propose replicating any institution's budget. It proposes adopting *architectural principles* (segmentation, federation, charters) that are *scale-independent*:

- **Virtual Local Area Network (VLAN) segmentation** requires no additional *hardware* budget — it is a configuration decision on existing switches; the cost is design and operational labour, not procurement;
- **Charters** are documents, not infrastructure purchases;
- **The Science DMZ** uses open-source tools (perfSONAR, Zeek) and NREN services already available through GEANT [28↗, 30↗];
- **Federated governance** is an organisational choice, not a technology procurement.

The evidence base deliberately spans institutions of different sizes: not only MIT and Stanford, but also smaller European universities, ETH Zürich, Michigan, NC State, Penn State and Wisconsin-Madison [19↗, 37↗, 38↗, 39↗]. The architectural principles are consistent across all sizes.

The scale argument actually favours federation: a small institution has *fewer* resources for a monolithic central team to manage everything. Federation distributes the workload to where domain expertise exists.

The deeper point: these are not larger institutions' choices to borrow, but a minimal necessary set. The functions the architecture discharges — authenticating users, protecting sensitive and personal data, segmenting, auditing — are required of *any* institution offering a digital infrastructure. Several are legally compelled with no size threshold: a data-protection duty applies to any institution processing personal data, irrespective of size, under the institution's applicable data-protection regime (in the EU, the GDPR [40↗], which applies irrespective of size). The choice a small institution faces is therefore not "afford the leading universities' model or not", but "discharge these already-owed obligations coherently and sovereignly, or implicitly and dependently". Only the instantiation scales with size; the obligations do not [16↗].

Q5.2 — "Cherry-picking successful models ignores failed federations"

The dossier only cites universities where federation works. What about universities that tried federation and failed, reverting to centralisation?

Answer to Q5.2

This is a fair challenge. Any honest analysis must consider counter-examples.

However:

1. The evidence base spans **a broad set of reference universities** across the US, UK, Switzerland and continental Europe, plus CERN, plus the wider NREN ecosystem. This is not cherry-picking — it is the *dominant pattern* in high-performing universities worldwide.
2. The EDUCAUSE Top 10 IT Issues [11↗] and EDUCAUSE IT-governance resources [23↗] consistently recommend federated governance for higher education. This is sector consensus, not anecdote.
3. Counter-examples of "failed federation" typically involve institutions that *federated without accountability mechanisms* (no charters, no SOC oversight, no minimum standards). The charter-based model addresses this risk directly.

The burden of evidence is symmetrical: if the questioner claims that federation fails, they should cite specific examples and show that the failures were caused by *federation itself* rather than by the absence of the governance mechanisms proposed here.

Q5.3 — "Those universities were built federated — we cannot retrofit federation onto a centralised institution"

MIT, Cambridge, and Stanford were *born* decentralised. Their federation is historical, not deliberate. You cannot impose federation on an institution that has been centralised for years.

Answer to Q5.3

Factually incorrect for several documented universities:

- **NC State** explicitly *redesigned* its IT governance for digital transformation, as documented in EDUCAUSE Review [37↗];
- **Penn State** *unified* IT professionals from centralised units while introducing participatory governance and SLAs [38↗];
- **Wisconsin-Madison** adopted federation as a deliberate "modernisation and federation" strategy [39↗];
- **University of Michigan** evolved from a more centralised model to formal federation with the creation of an IT Council [19↗].

Federation is not a "natural state" — it is a *governance choice* that can be adopted, with appropriate transition planning. The progressive transition plan (governance first, then pilot on selected entities, then gradual extension) is designed precisely for institutions moving *from* centralisation *to* federation.

Q5.4 — "The reversibility claim rests on soft, single-vendor conformance tests"

The lock-in answer rests on exit tests and a reversibility playbook; if those tests are anchored on single-vendor specifications, the guarantee is soft.

Answer to Q5.4

The exit tests are cross-implementation by design, not single-vendor. Each replaceable layer is tested against an *alternative* implementation: System for Cross-domain Identity Management (SCIM) user/group export to an alternative identity provider, policy bundles re-imported into an alternative engine, container images to an alternative OCI registry, switch configuration to an alternative-vendor device, the analytical store re-pointed, and object-store operations against an independent S3-compatible implementation. Reversibility is therefore a tested property once the institution runs these exit tests, not a vendor promise — developed in full in the standalone Technical Reference [16↗].

6 Questions on the independent adjustments commission

> "Injustice anywhere is a threat to justice everywhere."
>
> — Martin Luther King Jr., *Letter from Birmingham Jail*, 1963

Q6.1 — "An independent adjustments commission creates bureaucratic overhead and slows down IT decisions"

Adding an independent commission that can override IT policy decisions introduces delays and bureaucracy into what should be agile operational decisions.

Answer to Q6.1

The Independent Commission for Reasonable Adjustments of Digital Policies (ICRADP) does not "override" operational decisions. It provides an *adjustment* mechanism for *individual* cases where a *general* policy creates a disproportionate obstacle for a specific person. This is analogous to a court system: the existence of courts does not slow down legislation; it corrects general rules that produce unjust outcomes in specific cases.

On timing:

- The commission rules within a short, published deadline — faster than many IT change-management processes;
- In documented emergencies (medical, professional), a provisional adjustment can be granted within a sharply shorter window;
- The commission handles *exceptions*, not routine operations. The segmented architecture, by providing appropriate zones for most needs, *reduces* the number of adjustment requests.

Cost of the alternative: without a formal mechanism, adjustment requests are handled through *informal negotiations* with the IT department — a process that is slower, less predictable, less fair, and produces no auditable record. The ICRADP *streamlines* exception handling by centralising and formalising it.

Q6.2 — "The commission is a Trojan horse to override IT security decisions"

Under the guise of "reasonable adjustments," every dissatisfied user will appeal to the commission to bypass security controls. The commission will become a mechanism for institutional circumvention of IT policy.

Answer to Q6.2

This concern is understandable; the following structural safeguards are designed precisely to prevent abuse:

1. *Documented justification:* requests must specify medical, personal, professional, or fundamental-rights grounds;
2. *Proportionality assessment:* the commission evaluates whether the adjustment creates a

disproportionate security risk (not merely an inconvenience for IT);

3. *Reasoned refusals:* the commission can and will refuse requests that do not meet the criteria;
4. *Annual transparency report:* statistics on granted/refused requests, preventing either systematic overriding or systematic refusal;
5. *The security function is heard:* the security perspective is formally considered in every decision.

Precedent: reasonable-adjustment committees that support students and staff operate on similar principles across many institutions and have not devolved into mechanisms for "bypassing" academic standards. Courts, ombudsmen, and appeal mechanisms exist in every well-governed institution without destroying the authority of the decision-makers they review.

The deeper issue: an IT department that cannot withstand *reasoned, independent review* of its policies is an IT department whose policies may not be defensible. Accountability mechanisms strengthen governance; they do not undermine it.

Q6.3 — "Citing fundamental rights for IT policy is emotional manipulation"

Invoking the EU Charter of Fundamental Rights, the ECHR, and human-rights case law for a discussion about firewall rules is disproportionate and emotionally manipulative. This conflates totalitarian censorship with ordinary IT administration.

Answer to Q6.3

The legal framework cited is binding, not rhetorical. Here is how it applies concretely:

- In EU jurisdictions, Article 13 of the EU Charter protects academic freedom as a *fundamental right* and applies to *universities* — that is not a stretch; it is the literal scope of the provision. Comparable jurisdictions protect academic freedom under their own constitutional or statutory instruments.
- The ECtHR in *Sorguç v. Turkey* [41↗] and *Erdoğan v. Turkey* [42↗] applied freedom-of-expression protections specifically to *academic* contexts.
- The CJEU in *Scarlet Extended v. SABAM* [43↗] ruled that *systematic filtering* of Internet traffic is incompatible with Article 11 of the Charter.
- The Grand Chamber in *Bărbulescu v. Romania* [44↗] established a **six-criteria proportionality test** for digital surveillance *in the workplace* — the exact context of university IT policies.

These are not abstract philosophical references. They are *binding law* in the EU and Council of Europe member states; where the adopter is so bound, an IT policy that systematically restricts digital access and monitors communications *must* satisfy the proportionality requirements of these instruments. Elsewhere, they stand as a strongly persuasive proportionality benchmark alongside the adopter's own fundamental-rights instruments.

Scale of the claim: the dossier does not compare university IT policies to totalitarian censorship. It argues that digital policies *engage* fundamental rights and must therefore pass a proportionality test. This is a measured, legally grounded claim — not emotional

manipulation.

Q6.4 — "Technostress and moral injury are not real occupational hazards — this is pseudoscience"

Technostress is a buzzword. Moral injury applies to soldiers, not to academics who cannot install software. Citing these concepts to argue against IT policies is scientifically dubious.

Answer to Q6.4

The scientific evidence is extensive and peer-reviewed:

Technostress: La Torre et al. [45↗] published a systematic review of **105 studies** in the *International Archives of Occupational and Environmental Health* (Springer), establishing technostress as a documented occupational risk with measurable effects on well-being and productivity. Tarafdar et al. [46↗] demonstrated its impact on role stress and performance in the *Journal of Management Information Systems*. Ragu-Nathan et al. [47↗] validated the construct empirically in *Information Systems Research*. These are top-tier peer-reviewed journals, not "buzzword" sources.

Moral injury: Litz et al. [48↗] introduced the construct in the *Clinical Psychology Review*. Williamson et al. [49↗] published a systematic review and meta-analysis in the *British Journal of Psychiatry*, extending the concept to *occupational* contexts. Hanna et al. [50↗] specifically studied moral injury in *university staff*. The concept is not limited to military contexts — it is a well-established framework in occupational psychology.

Dismissing peer-reviewed systematic reviews as "pseudoscience" without engaging the evidence is itself an unscientific position. One may disagree with the *policy implications* drawn from this literature, but denying the documented phenomena requires counter-evidence, not dismissal. These findings describe documented risks; the dossier pairs them with the mitigation it proposes (proportionate policy and an adjustments mechanism), not with a claim that restriction is always harmful.

7 Questions prompted by recent incidents

> "Data is not information, information is not knowledge, knowledge is not understanding, understanding is not wisdom."
>
> — Russell L. Ackoff, *From Data to Wisdom*, 1989

Q7.1 — "Recent university breaches prove we need MORE restriction, not less"

The headlines are clear: universities are under siege from ransomware and supply-chain compromises. This is not the time to relax security by giving departments autonomy.

Answer to Q7.1

This is a frequently heard interpretation that warrants careful factual examination. Sector incident analysis points consistently to a small set of root causes:

- **Third-party software vulnerabilities (supply chain):** neither "more restriction" on research zones nor "less department autonomy" would have prevented them. The mitigation is vendor risk management, patching, and *isolation of critical applications* — which is what segmentation achieves.
- **Centralised administrative perimeters:** ransomware that exploits a single undifferentiated perimeter is amplified by the *absence* of segmentation, where email, data servers, and administrative services share one perimeter.
- **Credential compromise and lateral movement:** segmentation is the standard defence against lateral movement [7↗].
- **Contained incidents:** where an incident *is* confined to a subnet, that is a demonstration that segmentation *works* [6↗].

None of these incident classes were caused by "openness," "federation," or "research-zone autonomy." They were caused by third-party vulnerabilities, credential compromise without segmentation, and centralised perimeters that became single points of failure. The Sophos State of Ransomware in Education 2025 [51↗] identifies "exploited vulnerabilities" and "unknown security gaps" as top causes — consistent with patching and segmentation, not with restriction. The proposed mechanisms (segmentation, enclaves, charters, zone-specific monitoring) *directly address* every one of these root causes; the "more restriction" response does not.

Q7.2 — "The incident analysis is biased — it selectively interprets failures to support its thesis"

Any incident can be interpreted multiple ways. Claiming that a centralised-perimeter breach proves the need for *less* centralisation is tendentious when it could equally prove the need for *stronger* centralisation.

Answer to Q7.2

This is a fair methodological challenge. Let us examine it rigorously.

The claim that a centralised-perimeter breach proves "stronger centralisation" would need to show that (i) the breach was caused by a *decentralised* part of the infrastructure, and (ii) a more centralised architecture would have prevented the specific attack vector.

The available evidence on the canonical cases shows the opposite: such attacks target *central administrative services* (email, data servers), and the damage is amplified wherever these services sit in a single, undifferentiated perimeter. Centralising *more* services into that perimeter would not have reduced the blast radius, and plausibly enlarges it.

The interpretation aligns with independent sector analysis:

- Verizon DBIR 2024 [7↗]: credential abuse and ransomware as the dominant measured breach patterns, whose in-network progression segmentation is designed to interrupt (per the NIST/ISO controls above);
- NIST SP 800-215 [52↗]: a guide to securing enterprise networks through segmentation;
- Sophos State of Ransomware in Education 2025 [51↗]: "exploited vulnerabilities" and "unknown security gaps" as top causes — consistent with patching and segmentation, not with restriction.

The analysis is not "selective interpretation" — it is alignment with the independent analysis of Verizon, Sophos, and NIST. The burden is on the questioner to show how "stronger centralisation" addresses the documented root causes.

8 Questions on regulatory interpretation

> "The law is reason, free from passion."
>
> — Aristotle, *Politics*

Q8.1 — "NIS2 may actually require MORE centralisation, not federation"

The NIS2 Directive requires incident notification, risk management, and governance. These requirements are easier to demonstrate with a single, centralised IT authority. Federation makes compliance harder.

Answer to Q8.1

NIS2 is requirements-based, not architecture-prescriptive. The Directive specifies *what* must be achieved (risk management, incident containment, governance) but does *not* prescribe *how* the infrastructure must be organised.

A federated architecture with a central SOC for detection and notification, per-zone risk assessments and incident playbooks, charters documenting responsibilities and contacts, and a digital-policy commission for strategic oversight, addresses each NIS2 Article 21(2) measure family — the organisational measures remain the institution's to implement and evidence (see the regulatory mapping) — while *also* providing the compartmentalisation that *improves* incident containment — a core NIS2 objective.

One locatable clock owner. Where the adopter is an essential or important entity under the applicable supranational and national legal framework, the central SOC owns the incident-reporting clock — in the EU, the NIS2 Article 23 timeline of a 24-hour early warning, a 72-hour notification and a one-month final report [53] — while the zone charters oblige each zone to report inward to the SOC within a sub-deadline. The single-owner pattern is generic: it applies to whatever incident-reporting regime governs the adopter, so federation does not fragment the reporting obligation but gives it a single, accountable owner.

ISO 27001 precedent: universities that achieve ISO 27001 certification commonly scope the certification to *central IT services* rather than the entire institution. Clause 4.3 of the standard [5] expressly permits such a bounded Information Security Management System (ISMS) scope, and certifiers accept this *de facto* federation as a valid scope definition.

The evidence argument: a multi-zone architecture with per-zone logging, incident playbooks and regular testing *produces more auditable evidence* than a single monolithic perimeter.

Q8.2 — "The GDPR 'risk-based' argument is too convenient — it could justify anything"

Saying that GDPR Article 32 requires measures "appropriate to the risk" does not mean an institution can decide to accept more risk. A supervisory authority could still sanction insufficient security even if the institution claims it assessed the risk.

Answer to Q8.2

Correct — the risk-based approach is not a carte blanche. GDPR Article 32 requires measures appropriate to the risk, taking into account the "state of the art, costs, context, and the likelihood/severity of risks" [40↗]. The institution must demonstrate that its choices are *justified*, not merely *convenient*.

However, this argument applies equally to the monolithic approach:

- A monolithic approach that *over-restricts* research and teaching while *under-protecting* the administrative enclave (because the same firewall handles both) may also fail the "appropriate to the risk" test — for different reasons;
- The "state of the art" element explicitly requires considering what comparable institutions do. The state of the art in higher education *is* segmented, federated architecture; an institution that ignores it may be *more* exposed to regulatory challenge, not less;
- The European Data Protection Board (EDPB) [54↗] and European Union Agency for Cybersecurity (ENISA) [55↗] confirm the risk-based interpretation and that measures must be *adapted to context* — not uniformly maximal.

The dossier does not argue for "less security." It argues for *differentiated* security: maximum where the risk is highest (administrative data), proportionate where the risk is lower (research). This is precisely what GDPR Article 32 contemplates.

Q8.3 — "The proposal never states a GDPR lawful basis or a DPIA trigger"

The proposal introduces new processing of personal data — per-zone monitoring, the audit pipeline (which logs subject and decision identifiers), AI-API access logging, and federated identity — yet it never states the GDPR Article 6 lawful basis, nor identifies an Article 35 DPIA trigger. Under the Article 5(2) accountability principle, a controller must be able to demonstrate its lawful basis; as written, a Data Protection Officer (DPO) could refuse the proposal on the ground that none is stated.

Answer to Q8.3

The concern is well founded, and the lawful basis is stated here explicitly. The proposal does introduce new processing, and under GDPR Article 5(2) the controller must be able to demonstrate its lawful basis [40↗].

Lawful basis. The controller identifies a lawful basis under the institution's applicable data-protection regime: a public-mission body typically relies on the public-interest task, a private body on legitimate interests or consent. In the EU instantiation, for a public university the monitoring, audit and identity processing rests on GDPR Article 6(1)(e) — processing necessary for a task carried out in the public interest (the institution's research and teaching mission and its statutory security obligations, including those under NIS2) — and, where appropriate, Article 6(1)(f) legitimate interests (network and information security, expressly recognised in Recital 49) — available only where the institution is not acting as a public authority in the performance of its tasks (Article 6(1), second subparagraph); for a public university so qualified under national law, Recital 49 informs the necessity test under

point (e) rather than supplying a separate basis — subject to the balancing test against data subjects' rights and freedoms. Any processing of special categories of data is conditioned on a corresponding Article 9 ground.

DPIA. Because the monitoring and audit pipeline use new technologies and entail systematic processing likely to result in high risk, they are expected to warrant a DPIA under Article 35(1) [40↗]. The proposal feeds that assessment rather than replacing it: the per-scenario audit records supply the systematic description, the necessity-and-proportionality analysis and the risk treatment an Article 35 DPIA requires. The per-processing lawful basis is finalised in the DPIA and the Record of Processing Activities, both maintained by the controller (Article 30(1)); the DPO advises on and monitors the DPIA (Articles 35(2) and 39(1)(c)).

This strengthens, rather than weakens, the proposal. A monolithic perimeter that monitors all traffic uniformly faces the *same* Article 6 and Article 35 obligations with *less* ability to scope and minimise. The segmented, context-bounded design keeps monitoring proportionate — per-zone scope, minimised audit fields, access-controlled logs — which is exactly what the necessity-and-proportionality test of Article 35 rewards.

Q8.4 — "Barbulescu is wielded outward but never applied to the proposal's own monitoring"

Q6.3 invokes the Bărbulescu six-criteria proportionality test against restrictive monitoring, but the proposal's own per-zone monitoring, SOC oversight and audit pipeline (logging subject and decision identifiers) are themselves surveillance — which the proposal never runs through the same six criteria. A reviewer could call this an asymmetry.

Answer to Q8.4

Fair point — the same test must, and does, apply to the proposal's own monitoring. The architecture's monitoring is surveillance in the Bărbulescu [44↗] sense and is assessed here against its six criteria:

1. **Prior notification:** monitoring is disclosed in advance through the zone charters and the institution's transparency notices.
2. **Extent and intrusion:** the audit pipeline records *metadata* (subject and decision identifiers, verdicts, timestamps), not communication *content*; monitoring is scoped per zone, not blanket, and retained for a bounded period.
3. **Legitimate justification:** the aim is network and information security and the institution's NIS2/GDPR duties — not performance or behavioural surveillance; access to any content would require the weightier justification Bărbulescu demands.
4. **Least intrusive means:** context-bounded, metadata-level monitoring is *less* intrusive than the blanket content inspection a monolithic perimeter tends toward.
5. **Consequences and use:** logs feed security operations and incident response under access controls; they are not a routine input to disciplinary or performance decisions.
6. **Safeguards:** SOC access controls, retention limits, DPO oversight and the DPIA (Q8.3) provide the safeguards Bărbulescu requires — especially the bar on routine content

access.

Far from exempting itself, the proposal's segmented, metadata-level design is what *lets* it satisfy the Bărbulescu criteria more readily than the uniform monitoring it replaces.

Collective dimension. Bărbulescu governs the *individual* proportionality test; in several jurisdictions a *collective* step precedes it: consultation or co-determination of the institution's staff-representation bodies before workplace-monitoring tools are deployed. The Technical Reference makes that consultation a Wave-2 precondition where the adopter's labour law so requires, and the ICRADP seat gives staff a standing voice once the pipeline operates.

Q8.5 — "Federated procurement leaves NIS2 supply-chain security (Art. 21(2)(d)) without an owner"

The incident answers address supply-chain risk only *after the fact*. NIS2 Article 21(2)(d) imposes a *forward*, standing duty to manage security in the supply chain and supplier relationships. Where zones and faculties procure their own tools, a security officer could refuse the proposal on the ground that no one owns supply-chain assurance *across* autonomous zones.

Answer to Q8.5

The obligation is real, forward-looking, and distinct from incident response — and it has a named owner here. The supply-chain-security duty of the applicable supranational and national legal framework (in the EU, NIS2 Article 21(2)(d) [53↗]) requires ongoing management of supplier and supply-chain security, not merely post-incident remediation.

The architecture already carries the control. The lifecycle wave, a supply-chain-attestation instantiation (signed provenance and SBOMs), and a procurement-clause workstream established in the foundations wave [16↗] produce software provenance and contractual security clauses applied to *every* acquisition, regardless of which zone procures it.

One accountable owner, mirroring the Article 23 clock. Just as the central SOC owns the NIS2 reporting clock (Q8.1), a central security-governance owner maintains the supplier-assurance baseline — the approved-supplier register, the mandatory procurement clauses, and the attestation requirements — while each zone charter binds local procurement to that baseline. Federation therefore does not fragment supply-chain assurance: it gives it a single, locatable owner with per-zone obligations reporting inward.

Q8.6 — "Data-subject rights are unfulfillable across federated zones and a distributed audit store"

Q8.3 and Q8.4 establish the lawful basis, DPIA and proportionality of monitoring, but never explain how the institution actually fulfils a data subject's Article 15 access, Article 16 rectification or Article 17 erasure request when identity is federated and the audit log is distributed across autonomous zones. A DPO could refuse on the ground that rights become unfulfillable in a distributed design.

Answer to Q8.6

The concern is well founded, and the same single-accountable-owner logic that locates the Article 23 clock (Q8.1) locates rights fulfilment. Distribution raises a genuine operability question; the design answers it with one front door, one map, and per-zone duties.

Central intake (one front door). A data-subject request is received and tracked at a single DPO-owned intake point, so the data subject never has to address individual zones.

Per-zone retrieval duty. Each zone charter carries a binding obligation to locate, return, rectify or erase the records it holds within a sub-deadline, reporting inward to the DPO — exactly as zones report inward to the SOC for incident notification.

Bounded retention and a locator. The audit pipeline records minimised *metadata* for a bounded period (Q8.4), so scheduled expiry makes Article 17 erasure tractable rather than a distributed deletion hunt; and the Article 30 Record of Processing Activities [40↗], maintained by the controller (Article 30(1)) and monitored by the DPO (Article 39(1)(b)), maps which zones and systems hold which categories of data, so any Article 15/16/17 request is routed deterministically across the federation.

The evidence store is itself a control. The audit trail that underwrites these rights is not assumed trustworthy: it is append-only and tamper-evident (per-record signing or hash-chaining), with separation of duties between operators and readers and a four-eyes rule on retention expiry, as specified in the Technical Reference's observability chapter. The record proving accountability therefore cannot be silently altered or selectively deleted (GDPR Art. 32 / Art. 5(1)(f); ISO/IEC 27001 A.8.15).

9 Questions on costs and feasibility

> "There is nothing more expensive than a missed opportunity."
>
> — Attributed to H. Jackson Brown Jr.

Q9.1 — "The cost analysis lacks concrete numbers — how much will this actually cost?"

The dossier discusses costs qualitatively but does not provide a detailed budget. Without concrete figures, the cost-benefit analysis is speculative.

Answer to Q9.1

This is a fair request and one that can only be fully addressed through a detailed implementation study specific to the institution's current infrastructure, contracts, and staffing.

What the dossier does provide:

- **The governance step** (commission, charters, digital-policy commission): predominantly *organisational* — no new infrastructure, implementable with existing staff;
- **The pilot step** (selected entities with domain expertise): standard open-source tools and NREN services already available through GEANT [30↗];
- **The extension step:** gradual rollout aligned with validated results;
- **Cost of inaction:** the global all-industry average data-breach cost reached $4.88M in 2024 [56↗] (the education sector sits below this average); talent drain, Shadow IT, and lost competitiveness in funding calls are additional indirect costs.

The absence of a line-item budget in a *policy proposal* is normal — the budget is produced during the implementation study that follows the governance step. The purpose is to demonstrate that the approach is *architecturally sound and scalable from a teaching-led to a research-intensive institution*, not to substitute for a procurement exercise.

The standalone Technical Reference [16↗] provides indicative operational envelopes per layer, three reference pace options for the migration (5/7/10-year horizons), and explicit discussion of the financial-sovereignty dimension of every architectural choice.

Q9.2 — "The transition plan is too optimistic"

Institutional change at universities is notoriously slow. The proposed progressive transition may face delays due to institutional inertia.

Answer to Q9.2

The progressive structure is designed to absorb delays:

- NC State completed a governance redesign within a comparable scope [37↗];
- NSF CC* grants that fund Science DMZ deployments typically run two to three years for full deployment at a single campus [13↗];

- The governance step is primarily *commission, charters, and documents* — it does not require infrastructure procurement, the usual bottleneck.

The transition is incremental, not deadline-driven. The progressive structure ensures that delays in one step do not create systemic risk — the institution benefits incrementally from each completed step.

The alternative timeline is worse: the current state (monolithic restriction, Shadow IT, regulatory uncertainty) does not improve with time. Every month of delay is a month of talent drain, Shadow IT risk, and missed compliance opportunities.

Q9.3 — "The economic case is asserted, not shown — the board cannot decide without figures"

This dossier asks the governing bodies to adopt the policy; the detailed, situation-specific costing would properly be commissioned from the CIO once they decide to proceed. But a board still needs an order of magnitude to take that decision — and as written the dossier gives no figures, so a CIO could note that the economic case has not been framed.

Answer to Q9.3

The detailed, situation-specific cost analysis is the CIO's to produce once the governing bodies request it; the dossier's task is to give the board a defensible order of magnitude and a cost shape, not to pre-empt that analysis.

1. **Cost shape.** The governance step (commission, charters, digital-policy commission) requires no new procurement; it does draw on existing staff, whose coordination and training time has to be budgeted. Cost-bearing items sit in later, optional waves (segmentation, Science DMZ, observability storage), each gated by the validated results of the prior step.
2. **A scalable benchmark.** Rather than invent a figure, the order of magnitude can be read from sector benchmarks: in the 2018 EDUCAUSE Core Data Service, US higher-education institutions allocated on average about 3.6% of central IT spending to information security (identity and access management included) [57↗], below the cross-industry averages reported in vendor benchmark data for the same period [58↗]. A board can therefore size the likely envelope from its enrolment and current IT budget, and ask the CIO to refine it.
3. **Cost of inaction.** The status quo is not free: the global all-industry average data-breach cost reached $4.88M in 2024 [56↗] (the education sector below it), with talent drain and Shadow-IT exposure growing with delay.

This frames precisely the decision the dossier asks of the governing bodies — to commission a costed implementation study — with enough quantified context (a scalable percentage and a quantified downside) to make that decision defensible, while leaving the precise TCO to the CIO.

Q9.4 — "Even if it is affordable, a small IT team cannot operate a heavyweight open-source stack"

The cost objection has a sharper, operational form: the reference stack names heavyweight platforms whose day-to-day operation demands specialist staff a small or teaching-led institution does not have. Affordability of acquisition is not the same as feasibility of operation.

Answer to Q9.4

The reference stack is the research-intensive instantiation, not a mandatory floor; the architecture is defined by its functional layers and the sovereignty grid, and each layer degrades to a managed or mutualised realisation as scale decreases.

1. **Operate by responsibility, not by platform.** A down-scaled profile draws compute and storage from a national research cloud, an NREN service, or a managed provider under a data-processing agreement [16↗]: the institution retains sovereignty over *where* and *under what terms* data sits without operating the underlying platforms itself.
2. **Roles are not headcount.** The role inventory describes responsibilities that, in a small institution, several of which are discharged by the same person; it is not summed into a minimum specialist team.
3. **Optional layers stay optional.** Components justified only at scale — the Science DMZ, dedicated observability storage — can be deferred entirely without weakening the rest of the architecture.

The operational burden therefore scales with the chosen instantiation, not with the architecture: a small institution adopts the same principles at a managed-service realisation it can actually run.

Q9.5 — "Our cyber-insurer's questionnaire forbids this: EDR everywhere, no unmanaged admin rights, full perimeter inspection — adopting the proposal voids our coverage"

Typical underwriting questionnaires require endpoint detection on every host, prohibit unmanaged administrator rights, and assume perimeter inspection of all traffic. Accountable researcher root access and a Science DMZ that bypasses the enterprise firewall facially contradict all three. Whatever the architecture's merits, the institution cannot operate uninsured.

Response Q9.5

This concern has merit in its premise: insurability is a genuine external gate, and "the architecture is sound" is not an answer an underwriter accepts. The response, however, runs in three steps — and its order matters.

1. **The proposal strengthens the insurable posture.** Network segmentation, institution-wide MFA, federated identity and classification-driven observability are precisely the control families underwriting commonly rewards; researcher root access is *accountable*, not unmanaged — charter-bound, logged, revocable, with a named

risk owner per zone (the enclave charter); and the Science DMZ is disclosable as a compensating-control architecture (ACL+IDS profile, dedicated transfer nodes, no general-purpose hosts — the documented ESnet pattern). The per-zone evidence of P14 and the maturity reporting produce, as a by-product, the documentation underwriters ask for at renewal.

2. **Where the questionnaire still conflicts, the first reflex is to renegotiate the contract, not the mission.** The report's **liberty-first rule** is that constraint is never preferred to freedom by default: a contract that would suppress an academic freedom is a contract to renegotiate. Concretely: engage the insurer or broker at Wave 0 with the zone catalogue and charters in hand; declare deviations as documented exceptions with compensating controls rather than letting a generic corporate questionnaire default the institution to "non-compliant"; and seek academic-context underwriting terms. Freedom has a price the governance body can knowingly choose to pay — retention of a residual risk, an alternative carrier, or sector mutualisation — rather than letting a standard form rewrite the institution's mission.
3. **At sector scale, the response is collective.** Where imposed terms would make academic digital freedom uninsurable by default, universities act together — through their consortia, NREN communities and sector bodies, in the same spirit as the dossier's Position C (influence and reform): engaging insurers, and where necessary the bodies that regulate them, so that the insurability of a university is assessed against the controls it actually operates, not against a template written for a single-perimeter corporation.

Bottom line. The questionnaire is an input to a negotiation, not a design authority. The proposal gives the institution both better terms to ask for and the evidence to ask with; the truly unanswerable position is the undocumented flat network.

10 Questions on methodology, process and credibility

> "The important thing is not to stop questioning. Curiosity has its own reason for existing."
>
> — Albert Einstein, *LIFE Magazine*, 1955

Q10.1 — "This document is biased — it was written to support a predetermined conclusion"

The dossier reads as an advocacy document, not an objective analysis. It selects evidence that supports federation and ignores evidence that supports centralisation.

Answer to Q10.1

Every policy document has a thesis. The distinction between a biased document and a well-argued one is whether the argument is supported by evidence and whether counter-arguments are addressed.

The evidence base:

- An extensive, fully referenced bibliography with verified sources;
- multiple reference university case studies across several countries;
- Major normative frameworks (NIST, ISO, COBIT, EU regulations);
- Sector organisations (EDUCAUSE, GEANT);
- Independent sector reports (Verizon DBIR, Sophos);
- A body of court decisions and legal instruments.

Counter-arguments are addressed: the incident analysis (Q7.1, Q7.2) directly engages with the strongest evidence that could be used *against* the thesis and demonstrates that it actually supports it. The risk register honestly catalogues the risks of the proposed approach. This very module demonstrates willingness to engage with criticism.

It is worth noting that maintaining the status quo is also a policy position that benefits from the same evidence-based scrutiny. The status quo is itself a position that should be defended with evidence — not treated as the neutral default.

Q10.2 — "This is an attack on the IT department / on the security function personally"

The dossier criticises the current approach so extensively that it amounts to a vote of no confidence in the IT department's competence.

Answer to Q10.2

The dossier critiques an *approach*, not *people*. The monolithic restriction approach is common in many institutions and is often adopted in good faith by competent professionals responding to genuine threats. The argument is that a *different* approach is more effective for a *university context* — not that the IT department is incompetent.

The proposals benefit the IT department:

- *Reduced perimeter:* the IT department focuses on the administrative enclave rather than trying to manage everything;
- *End of ad hoc exceptions:* charters and the ICRADP replace informal, time-consuming negotiations;
- *Clear accountability:* departments take formal responsibility for their zones instead of blaming central IT when things go wrong;
- *Better regulatory posture:* an evidence-producing architecture strengthens the security function's position in audits.

Policy evolution is a normal institutional process. Every institution periodically re-evaluates its approaches; this dossier is a contribution to that ongoing dialogue, not an indictment.

Q10.3 — "The document was partially written with AI tools — therefore it cannot be trusted"

The dossier acknowledges using AI tools in its composition. This undermines its credibility as a serious academic contribution.

Answer to Q10.3

This is a *genetic fallacy*: evaluating an argument by its origin rather than its content. The validity of the dossier depends on:

1. The accuracy of its factual claims (verifiable through its extensive base of cited sources);
2. The soundness of its reasoning (evaluable on its logical merits);
3. The robustness of its recommendations (assessable against established frameworks).

None of these are affected by whether the text was drafted with AI assistance, a typewriter, or a quill pen. The AI Act itself recognises this: it regulates AI *systems deployed in the real world*, not AI used as a writing tool [35↗]. LLMs produce nothing without human direction; the differentiating factor is the disciplined, review-bound workflow around the tool, not the tool itself.

Transparency: the explicit disclosure of AI-assisted composition is an act of intellectual honesty, not a weakness. Demanding disclosure and then using the disclosure to discredit the work is a rhetorical trap.

Scientific standard: the relevant question for any document is whether the claims are accurate, the sources verifiable, and the reasoning sound. These criteria apply regardless of the drafting tools used.

11 Summary: quick-reference table

Table 1: Quick-reference summary of questions and key points

Ref.	Question (summary)	Key points
Q1.1	Segmentation increases complexity	Complexity ≠ attack surface; NIST mandates segmentation; phased rollout + SDN mitigate
Q1.2	Single perimeter = better visibility	Single firewall creates bottlenecks; per-zone monitoring gives greater total observability
Q1.3	"You just want less security"	*Ad hominem*; proposals endorsed by NIST, ISO, EDUCAUSE, and a broad set of reference universities
Q1.4	Firebreak analogy is misleading	Analogy has limits; principle stands on NIST/Verizon evidence independently
Q1.5	Zero Trust claimed but SASE/ZTNA excluded	Maps to all seven SP 800-207 tenets; SASE/ZTNA declined as a sovereignty choice, not Zero Trust
Q2.1	Federation creates accountability gaps	Charters + SOC + zone owners create *more* granular accountability
Q2.2	Departments will be irresponsible	Risk acknowledged; mitigated by charters, SOC, default-deny, isolation, audits
Q2.3	Undermines the security function's authority	COBIT/Weill-Ross: governance ≠ management; no major university gives one officer unilateral authority
Q2.4	Academics lack security expertise	Distinction between technical implementation and policy direction; every framework requires stakeholder input
Q3.1	Root access is unacceptable risk	ETH model: accountable root access + isolation is safer than shadow root access
Q3.2	Autonomy unfairly burdens researchers	Central IT still provides backbone/SOC; Data Stewards + local ISGs bridge the gap
Q3.3	Science DMZ bypasses security	Replaces firewall with ACLs + Zeek IDS; endorsed by DoE/NSF; 100+ deployments
Q3.4	Not deployed locally, so unsuitable	Appeal to absence; substrate often present; non-deployment reflects funding routes, not merit; mutualised form proposed

Continued on next page

Ref.	Question (summary)	Key points
Q4.1	BYOD is inherently insecure	BYOD exists regardless; progressive interoperability + Zero Trust is safer than unmanaged
Q4.2	Commercial AI creates GDPR liability	Differentiated framework: adequacy or SCCs+TIA with supplementary measures, data classification, AI Act risk-based classification, traceability
Q4.3	AI access is convenience, not necessity	Status-quo bias; AI is structural for research/teaching; blocking creates shadow AI
Q5.1	We are not MIT/Stanford	False equivalence; principles are scale-independent; evidence spans institutions of all sizes
Q5.2	Cherry-picked success stories	Broad set of reference universities + sector consensus (EDUCAUSE); counter-examples welcome
Q5.3	Cannot retrofit federation	NC State, Penn State, Wisconsin-Madison, Michigan deliberately transitioned to federation
Q5.4	Reversibility rests on single-vendor tests	Exit tests are cross-implementation by design; a property tested when the institution runs them, not a vendor promise
Q6.1	Adjustments commission creates bureaucracy	Short published deadlines; handles exceptions, not routine; formalises existing informal process
Q6.2	Commission could be misused	Structural safeguards: documented justification, proportionality, security function heard, transparency
Q6.3	Citing rights is disproportionate	Binding EU/ECHR law, not philosophy; CJEU/ECtHR case law directly applies
Q6.4	Technostress is pseudoscience	105-study systematic review (La Torre 2019); peer-reviewed in top journals
Q7.1	Recent breaches prove need for restriction	Root causes are supply chain, credentials, lack of segmentation — not openness
Q7.2	Incident analysis is biased	Interpretation aligns with Verizon DBIR, NIST, Sophos independently

Continued on next page

Ref.	Question (summary)	Key points
Q8.1	NIS2 requires centralisation	NIS2 is requirements-based, not architecture-prescriptive; federation addresses each Art. 21(2) measure family with one clock owner, organisational measures remaining the institution's to evidence
Q8.2	Risk-based argument is too convenient	Applies symmetrically; state of the art is segmented architecture; EDPB/ENISA confirm
Q8.3	No GDPR lawful basis / DPIA trigger stated	Art. 6(1)(e)/(f) basis stated; Art. 35 DPIA expected; segmentation aids data minimisation
Q8.4	Bărbulescu not applied to own monitoring	Metadata-only, per-zone, disclosed monitoring satisfies the six criteria
Q8.5	NIS2 supply-chain (Art. 21(2)(d)) unowned	Attestation + procurement clauses; central assurance owner, per-zone duties
Q8.6	Data-subject rights unfulfillable when federated	Central DPO intake + per-zone retrieval duty + bounded retention + Art. 30 RoPA locator
Q9.1	No concrete budget numbers	Normal for policy documents; budget produced after governance step; open-source/NREN tools minimise cost
Q9.2	Timeline is too optimistic	Phased structure absorbs delays; status quo worsens with time
Q9.3	Economic case is asserted, not shown	Cost shape + scalable benchmark (US higher education's 3.6% security share of central IT spending, 2018 data, vs cross-industry averages) + cost of inaction frame the board decision
Q9.4	Small team cannot operate the stack	Reference stack is the high-scale instantiation; layers degrade to managed/mutualised realisations
Q9.5	Insurer's questionnaire forbids researcher root / Science DMZ	Underwriting credits + disclosable compensating controls; renegotiate for academic-context terms (questionnaire is negotiation input, not design authority); collective action in the spirit of Position C

Continued on next page

Ref.	Question (summary)	Key points
Q10.1	Document is biased	Extensively referenced, counter-arguments addressed, risk register honest
Q10.2	Attack on the IT department	Critiques approach, not people; proposals benefit IT department
Q10.3	AI-assisted = untrustworthy	Genetic fallacy; validity depends on accuracy/reasoning, not drafting tools

© SUITOAAD

12 Summary and outlook

> "The test of a first-rate intelligence is the ability to hold two opposed ideas in mind at the same time and still retain the ability to function."
>
> — F. Scott Fitzgerald, *The Crack-Up*, 1936

The systematic treatment of the frequently raised questions above supports four conclusions:

1. **No question invalidates the core thesis.** Every genuine concern (complexity, accountability, costs, feasibility) is met by a specific mechanism (phased rollout, charters, SOC oversight, open-source tooling). Some questions have partial merit and highlight implementation risks that must be managed; the risk register acknowledges these.

2. **Several questions rest on premises that, on examination, require correction or additional context.** These are addressed through clarification rather than rebuttal, and the underlying concerns are taken seriously in each case.

3. **The evidence base is robust:** an extensive, fully referenced base, multiple documented university case studies, and alignment with NIST, ISO, COBIT, the EU regulatory framework, EDUCAUSE, and independent sector reports. Engaging constructively with this evidence is the most productive path toward sound IT governance decisions.

4. **The strongest argument is convergence:** MIT, Stanford, Cambridge, Oxford, ETH Zürich, CERN, Michigan, Wisconsin-Madison, NC State, Penn State — and the 100-plus universities operating a Science DMZ — converge on segmented, federated architectures, while NIST, ISO, EDUCAUSE, GEANT, and the EU regulatory framework all support risk-based, proportionate security. When both practice and theory converge this strongly, an institution choosing a fundamentally different path should articulate the evidence supporting that alternative.

The proposals are grounded in extensive evidence, aligned with major governance frameworks, and internationally validated. Their implementation will require careful management, but they offer a robust foundation for constructive dialogue. Further questions are welcome.

References

[1] SUIT Working Group. *SUIT — Sustainable University IT Infrastructure & Technology*. SUIT Working Group reference document suite. Reference document suite of the SUIT Working Group, https://github.com/suit-working-group. Always-living document. 2026. URL: https://github.com/suit-working-group/suit-suite.

[2] *Magna Charta Universitatum*. Bologne, 18 septembre 1988 (révisée 2020) — For university IT governance, the MCU 2020 provides the principled foundation for institutional independence in digital infrastructure decisions, protection of academic freedom in digital environments, and ethical frameworks for technology deployment. 1988. URL: https://www.magna-charta.org/magna-charta-universitatum/mcu2020.

[3] NIST. *Security and Privacy Controls for Information Systems and Organizations*. Tech. rep. NIST SP 800-53 Rev. 5. For academic institutions, adopting these controls strengthens cybersecurity posture while meeting requirements under the Federal Information Security Modernization Act (FISMA) and other regulatory mandates that apply to federally-funded research operations. National Institute of Standards and Technology, 2020. DOI: 10.6028/NIST.SP.800-53r5. URL: https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final.

[4] NIST. *The NIST Cybersecurity Framework (CSF) 2.0*. Tech. rep. NIST CSWP 29. The CSF 2.0 is a foundational tool for academic institutions seeking to establish or enhance their cybersecurity governance posture and align risk management efforts with standardized best practices across all sectors. National Institute of Standards and Technology, Feb. 2024. DOI: 10.6028/NIST.CSWP.29. URL: https://www.nist.gov/cyberframework.

[5] ISO/IEC. *ISO/IEC 27001:2022 — Information Security, Cybersecurity and Privacy Protection — Information Security Management Systems — Requirements*. ISO/IEC 27001:2022 is the world's best-known standard for information security management systems (ISMS). For universities, it provides a comprehensive framework for managing information security risks across IT infrastructure, research data, and institutional operations. The 2022 revision updates the standard to address emerging threats in cloud security and data privacy. 2022. URL: https://www.iso.org/standard/27001.

[6] Ouest-France et al. *L'Université de Rennes victime d'une cyberattaque*. Ouest-France. March 2025; FunkSec group, ISTIC subnet. — L'Université de Rennes a annoncé le 10 mars 2025 avoir été victime d'une cyberattaque durant le week-end du 8–9 mars 2025 sur un sous-réseau pédagogique. FunkSec revendique 50 Go de données volées. Un VPN-SSL Fortinet utilisé par l'ISTIC a apparemment permis la compromission. 2025. URL: https://www.ouest-france.fr/bretagne/rennes-35000/luniversite-de-rennes-victime-dune-cyberattaque-5559d17c-fd9b-11ef-96f1-e130525ba9af.

[7] Verizon Business. *2024 Data Breach Investigations Report*. Verizon. Comprehensive annual analysis of cybersecurity incidents and data breaches across multiple industry sectors, including education. Draws on thousands of real-world incidents, identifies prevailing attack patterns, threat actor profiles, and vulnerability exploitation trends. Findings on ransomware prevalence, credential theft, and social engineering are directly applicable to university cybersecurity governance and risk management strategies. 2024. URL: https://www.verizon.com/business/resources/reports/dbir.html.

[8] ESnet. *Science DMZ for Pennsylvania State University and Virginia Tech Transportation Institute*. Energy Sciences Network — Science DMZ Case Studies. Single-institution case (Penn State College of Engineering / VTTI). Source of the 50 Mbps -> 5x/ 12x figures used in the suite. The degradation is a single documented case, not a general property of stateful firewalls. URL: https://www.es.net/science-engagement/knowledge-base/case-studies/science-dmz-case-studies/science-dmz-for-pennsylvania-state-university-and-virginia-tech-transportation-institute/.

[9] CERN Computer Security Team. *Computer Security vs. Academic Freedom*. CERN. Original description extracted from home.web.cern.ch/news/news/computing/computer-security-vs-academic-freedom. — AI-generated contextual summary: this resource provides a principled framework for how academic institutions can protect their infrastructure through transparent communication and proportionate measures without creating an overly restrictive environment that stifles research and innovation. URL: https://home.web.cern.ch/news/news/computing/computer-security-vs-academic-freedom.

[10] University of Michigan. *Safe Computing — Data Classification Levels*. University of Michigan. Site blocks bots with HTTP 403; no original description recoverable. — AI-generated contextual summary: the University of Michigan Safe Computing website defines the institution's data classification framework, categorizing institutional data into sensitivity levels (High, Moderate, Low) to guide appropriate handling, storage, and protection measures. This classification system establishes security requirements proportional to data sensitivity, covering everything from public information to regulated data such as HIPAA and FERPA records. The framework is central to the university's cybersecurity governance, enabling consistent data protection policies across a large, decentralized institution. URL: https://safecomputing.umich.edu/protect-the-u/safely-use-sensitive-data/classification-levels.

[11] EDUCAUSE. *Top 10 IT Issues 2024: Institutional Resilience*. EDUCAUSE Review. Flagship annual publication directly relevant to strategic planning for university IT infrastructure and academic governance, addressing critical issues including cybersecurity, data governance, enrollment management, student success analytics, and cost reduction. 2024. URL: https://www.educause.edu/research-and-publications/research/top-10-it-issues-technologies-and-trends/2024.

[12] ESnet. *Science DMZ: Breaking Down Data Barriers, Speeding up Science*. Energy Sciences Network. ESnet has been a pioneer in high-performance networking, contributing to the development of internet protocols, data management architecture, and software-defined networking. For academic institutions, ESnet's Science DMZ model and networking innovations offer relevant blueprints for optimizing large-scale research data transfers. URL: https://www.es.net/about/esnet-history/.

[13] NSF. *Campus Cyberinfrastructure (CC*) Program*. National Science Foundation. Original description extracted from nsf.gov/funding/opportunities/cc-campus-cyberinfrastructure. — AI-generated contextual summary: this funding initiative directly supports university IT modernization by addressing disparities in cyber-connectivity and emphasizing science-driven infrastructure needs to enhance institutional competitiveness. URL: https://www.nsf.gov/funding/opportunities/cc-campus-cyberinfrastructure.

[14] ISACA. *COBIT 2019 Framework: Introduction and Methodology*. For universities, COBIT offers tools for optimizing IT governance, managing risks, establishing controls, and supporting digital transformation initiatives critical to protecting institutional data and ensuring regulatory compliance. ISACA, 2018. URL: https://www.isaca.org/resources/cobit.

[15] Scott Rose, Oliver Borchert, Stu Mitchell, and Sean Connelly. *Zero Trust Architecture*. Tech. rep. NIST SP 800-207. This framework is particularly relevant for university IT infrastructure as institutions increasingly support remote work, personal devices, and cloud-based services that fall outside traditional network boundaries, necessitating resource-level protection rather than perimeter-based defenses. National Institute of Standards and Technology, Aug. 2020. DOI: 10.6028/NIST.SP.800-207. URL: https://csrc.nist.gov/publications/detail/sp/800-207/final.

[16] SUIT Working Group. *Sustainable University IT — A Technical Reference for Architecture and Migration*. Technical reference and migration playbook. Companion technical document to the report *The University Spirit in the Digital Age — For an Open, Secure and Mission-Aligned Digital Infrastructure*. Produced by the SUIT Working Group, https://github.com/suit-working-group. Always-living document; version 2.1, May 2026. SUIT Working Group, 2026. URL: https://github.com/suit-working-group/suit-suite.

[17] University of Oxford. *Information Security — Policy Framework and Governance*. University of Oxford Information Security. Original description extracted from infosec.ox.ac.uk/guidance-policy. — AI-generated contextual summary: the resource functions as the institutional backbone for ensuring consistent security practices across Oxford's collegiate structure, outlining how security accountability flows through divisional and departmental leadership. URL: https://www.infosec.ox.ac.uk/guidance-policy.

[18] ETH Zurich. *IT Baseline Protection Rules*. ETH Zurich Informatikdienste. Description derived from ETH Zurich Staffnet and ITS Blog announcements (direct PDF not parseable). — AI-generated contextual summary: these baseline protection rules are a foundational element of ETH Zurich's cybersecurity governance, ensuring a consistent minimum security posture across diverse departmental IT infrastructures through mandatory standards for system configuration, access control, and data protection. URL: https://ethz.ch/content/dam/ethz/main/eth-zurich/organisation/rechtssammlung/203.23en.pdf.

[19] University of Michigan. *IT Council*. University of Michigan. Site blocks bots with HTTP 403; no original description recoverable. — AI-generated contextual summary: the University of Michigan IT Council is a governance body that provides strategic direction and oversight for information technology across the university. It brings together IT leaders from schools, colleges, and administrative units to coordinate technology planning, policy development, and resource allocation in support of the university's academic and research missions. URL: https://it.umich.edu/governance/it-council.

[20] ETH Zurich, D-INFK. *Agreement Regarding Administrator Rights*. ISG D-INFK, ETH Zurich. Original description extracted from isg.inf.ethz.ch/Main/AboutUsDocuments. — AI-generated contextual summary: these documents establish governance frameworks for institutional IT infrastructure usage, acceptable conduct, and system maintenance protocols, directly supporting institutional compliance and proper stewardship of departmental computing resources. URL: https://www.isg.inf.ethz.ch/Main/AboutUsDocuments.

[21] Peter Weill and Jeanne W. Ross. *IT Governance: How Top Performers Manage IT Decision Rights for Superior Results*. Highly relevant to university governance as it provides actionable models for structuring IT decision-making authority, accountability, and strategic alignment within complex organizations. Harvard Business School Press, 2004. ISBN: 978-1591392538. URL: https://hbsp.harvard.edu/product/4783-HBK-ENG.

[22] Steven De Haes and Wim Van Grembergen. *Enterprise Governance of Information Technology*. 2nd. Management for Professionals. Directly relevant to university IT governance as it defines processes and structures that enable boards and IT professionals to align technology decisions with institutional strategic objectives. Springer, 2015. DOI: 10.1007/978-3-319-14547-1. URL: https://link.springer.com/book/10.1007/978-3-319-14547-1.

[23] EDUCAUSE. *IT Governance in Higher Education*. EDUCAUSE. The EDUCAUSE IT Governance resource collection provides frameworks, toolkits, checklists, and case studies for implementing effective IT governance, risk, and compliance (GRC) programs in higher education institutions, including the IT Governance Toolkit and the Higher Education IT Governance Checklist. URL: https://library.educause.edu/topics/it-professional-services/it-governance.

[24] CERN Computer Security Team. *Computer Security: TN v3.0*. CERN. Original description extracted from home.cern/news/news/computing/computer-security-tn-v30. — AI-generated contextual summary: this resource demonstrates how large research institutions implement progressive network segmentation strategies to balance security with operational needs, protecting critical accelerator control systems while accommodating modern technologies. URL: https://home.cern/news/news/computing/computer-security-tn-v30.

[25] ETH Zurich. *Data Stewardship at ETH Zurich*. ETH Library — Research Data Management. Original description extracted from library.ethz.ch data stewardship page. — AI-generated contextual summary: the resource profiles individual data stewards from various departments and explains their roles in implementing open research data practices, managing research workflows, and ensuring compliance with institutional guidelines, aligning with national open science initiatives. URL: https://library.ethz.ch/en/researching-and-publishing/data-management-and-policies/research-data-management/data-stewardship.html.

[26] ISG D-INFK. *IT Service Group — Department of Computer Science*. ETH Zurich. Original description extracted from isg.inf.ethz.ch. — AI-generated contextual summary: this resource demonstrates the departmental-level IT support model at ETH Zurich, where specialized IT groups operate alongside central IT services to meet discipline-specific computing needs. URL: https://www.isg.inf.ethz.ch/.

[27] Vern Paxson. "Bro: A System for Detecting Network Intruders in Real-Time". In: *Computer Networks* 31.23–24 (1999). Last consulted 15 February 2026. Foundational network intrusion detection system enabling comprehensive security monitoring across heterogeneous computing environments without host-level agents. Particularly relevant to universities managing thousands of diverse devices. Now maintained as the Zeek project., pp. 2435–2463. DOI: 10.1016/S1389-1286(99)00112-7. URL: https://www.icir.org/vern/papers/bro-CN99.html.

[28] *perfSONAR — Network Measurement Toolkit*. Original description extracted from perfsonar.net. — AI-generated contextual summary: the global infrastructure assists engineering teams in troubleshooting and helps increase productivity when utilizing network resources, making it particularly valuable for universities managing complex research and educational networks. URL: https://www.perfsonar.net/.

[29] Eli Dart, Lauren Rotman, Brian Tierney, Mary Hester, and Jason Zurawski. "The Science DMZ: A Network Design Pattern for Data-Intensive Science". In: *Proceedings of the International Conference for High Performance Computing, Networking, Storage and Analysis (SC'13)*. Last consulted 15 February 2026. Introduces the Science DMZ network design pattern for data-intensive scientific workflows. Developed at ESnet and widely adopted by universities and research laboratories as a reference architecture for segregating high-performance research traffic from enterprise networks. ACM, 2013. DOI: 10.1145/2503210.2503245. URL: https://dl.acm.org/doi/10.1145/2503210.2503245.

[30] GÉANT. *GÉANT — Pan-European Research and Education Network*. Original description extracted from about.geant.org/about/ (main site blocks bots with 403). — AI-generated contextual summary: GÉANT provides critical infrastructure for university IT connectivity, cybersecurity collaboration, and international academic research networking, enabling European researchers to lead international collaboration. URL: https://geant.org.

[31] ESnet. *Science DMZ Case Studies*. Energy Sciences Network. ESnet case studies demonstrating how high-speed network infrastructure resolves scientific computing challenges at national laboratories and research institutions, including OSCARS circuit management and Science DMZ architecture. Directly relevant to university IT professionals seeking practical guidance on deploying research data infrastructure. URL: https://www.es.net/science-engagement/knowledge-base/case-studies/.

[32] Sean Peisert, Eli Dart, William K. Barnett, James Cuff, Robert L. Grossman, Edward Balas, Ari Berman, Anurag Shankar, and Brian Tierney. "The Medical Science DMZ: A Network Design Pattern for Data-Intensive Medical Science". In: *Journal of the American Medical Informatics Association* 25.3 (2018). Last consulted 15 February 2026. Highly relevant to academic institutions managing sensitive research data, offering three production implementations from Indiana University, Harvard, and the University of Chicago as practical models for balancing HIPAA regulatory compliance with infrastructure performance., pp. 267–274. DOI: 10.1093/jamia/ocx104. URL: https://pmc.ncbi.nlm.nih.gov/articles/PMC7651886/.

[33] *Science DMZ Networks: How Different Are They Really?* NSF Public Access Repository. Last consulted 15 February 2026. Two-year quantitative study finding that Science DMZ networks exhibit lower latency, higher throughput, and lower jitter, but also non-intuitive results. Relevant to universities evaluating Science DMZ deployment for research network performance. 2024. URL: https://doi.org/10.1109/LCN60385.2024.10639626.

[34] Klaas Wierenga and Licia Florio. "eduroam: Past, Present and Future". In: *Computational Methods in Science and Technology* 11.2 (2005). Last consulted 15 February 2026. Foundational component of modern university IT infrastructure, establishing the concepts and protocols for secure roaming services. eduroam now spans over 100 countries and is a key element of federated identity management for academic institutions., pp. 169–173. DOI: 10.12921/cmst.2005.11.02.169-173. URL: https://cmst.eu/articles/eduroam-past-present-and-future/.

[35] *Regulation (EU) 2024/1689 of the European Parliament and of the Council laying down harmonised rules on artificial intelligence (Artificial Intelligence Act)*. OJ L, 12 July 2024. Articles 2(6), 2(8): exemptions for scientific research and R&D — This regulation requires institutions deploying AI in education, admissions, or research to conduct conformity assessments, maintain documentation, and ensure human oversight while benefiting from research exemptions. 2024. URL: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32024R1689.

[36] William Samuelson and Richard Zeckhauser. "Status Quo Bias in Decision Making". In: *Journal of Risk and Uncertainty* 1.1 (1988). Last consulted 15 February 2026. Highly relevant to university IT governance: explains institutional resistance to infrastructure modernization, policy reform, and adoption of new cybersecurity frameworks, illuminating why organizations often persist with suboptimal legacy systems and outdated governance structures., pp. 7–59. DOI: 10.1007/BF00055564. URL: https://link.springer.com/article/10.1007/BF00055564.

[37] Debbie Carraway and Marc Hoit. "Redesigning IT Governance for Digital Transformation at North Carolina State University". In: *EDUCAUSE Review* (Mar. 2019). EDUCAUSE Review blocks bots with HTTP 403; no original abstract recoverable. — AI-generated contextual summary: this article describes how North Carolina State University redesigned its IT governance structure to support digital transformation, detailing the transition from a traditional committee-based governance model to a more agile framework that aligns

IT decision-making with institutional strategic priorities, emphasizing stakeholder engagement and portfolio management approaches. The article provides a practical case study of how a large research university can modernize IT governance to be more responsive to rapidly evolving technology needs while maintaining broad campus participation. URL: https://er.educause.edu/articles/2019/3/redesigning-it-governance-for-digital-transformation-at-north-carolina-state-university.

[38] Penn State. *IT Transformation: Participatory Governance with SLAs*. Penn State University. Original description extracted from psu.edu news article. — AI-generated contextual summary: this initiative represents a shift toward centralized IT governance and shared services, with dedicated workstreams addressing seven areas including IT governance, financial taxonomy, and solution delivery. URL: https://www.psu.edu/news/administration/story/it-begins-transition-shared-services-model.

[39] Lois Brooks. *Working Smarter Together through Modernization & Federation*. UW-Madison IT — CIO Blog. Original description extracted from it.wisc.edu CIO blog post. — AI-generated contextual summary: the piece emphasizes that effective IT modernization depends on prioritizing collaboration, professional development, and people-centered governance to support the university's diverse academic and research missions while reducing cybersecurity risks and administrative costs. URL: https://it.wisc.edu/lois-brooks-cio-blog/working-smarter-together-through-modernization-and-federation/.

[40] *Règlement (UE) 2016/679 du Parlement européen et du Conseil relatif à la protection des personnes physiques à l'égard du traitement des données à caractère personnel (RGPD)*. Article 32 : Sécurité du traitement — The GDPR imposes compliance requirements on student and employee data handling, research data management, cybersecurity incident response protocols, and IT infrastructure standards. Article 32 specifically mandates appropriate technical and organizational security measures. 2016. URL: https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32016R0679.

[41] CEDH. *Sorguç c. Turquie*. Req. n° 17089/03, 23 juin 2009 — This case establishes that universities must protect freedom of academic expression, including critical discourse, and cannot use disciplinary or IT-related measures to suppress legitimate scholarly debate. 2009. URL: https://hudoc.echr.coe.int/eng?i=001-93161.

[42] CEDH. *Mustafa Erdoğan et autres c. Turquie*. Req. n°s 346/04, 39779/04, 27 mai 2014 — This case reinforces that institutional policies – including IT acceptable-use policies and publication guidelines – must not be used to silence legitimate academic criticism or restrict scholarly discourse. 2014. URL: https://hudoc.echr.coe.int/eng?i=001-144129.

[43] CJUE. *Scarlet Extended SA c. SABAM*. Aff. C-70/10, 24 novembre 2011 — This ruling limits the scope of network filtering and surveillance measures that institutions can impose on their networks. Indiscriminate monitoring of all electronic communications on a network is incompatible with the EU Charter of Fundamental Rights. 2011. URL: https://curia.europa.eu/juris/liste.jsf?num=C-70/10.

[44] CEDH (Grande Chambre). *Bărbulescu c. Roumanie*. Req. n° 61496/08, 5 septembre 2017 — This case is of paramount relevance to university IT infrastructure governance, as it directly shapes policies on monitoring of email, messaging, and internet use on institutional networks, requiring transparent, proportionate, and well-documented surveillance practices. The Court set out six criteria (the "Barbulescu criteria") that domestic courts must assess when balancing employer monitoring against employee privacy. 2017. URL: https://hudoc.echr.coe.int/fre?i=001-177082.

[45] Giuseppe La Torre, Angela Esposito, Ilaria Sciarra, and Marta Chiappetta. "Definition, Symptoms and Risk of Techno-stress: A Systematic Review". In: *International Archives of Occupational and Environmental Health* 92 (2019). Last consulted 15 February 2026. Comprehensive synthesis relevant to university IT infrastructure planning as it provides an evidence base for designing institutional policies and support systems that mitigate the occupational health risks associated with pervasive technology use in academic settings., pp. 13–35. DOI: 10.1007/s00420-018-1352-1. URL: https://doi.org/10.1007/s00420-018-1352-1.

[46] Monideepa Tarafdar, Qiang Tu, and T. S. Ragu-Nathan. "The Impact of Technostress on Role Stress and Productivity". In: *Journal of Management Information Systems* 24.1 (2007). Last consulted 15 February 2026. Relevant to university IT infrastructure management as it provides evidence that stress caused by rapid technology adoption and complexity in academic computing environments can significantly reduce staff and faculty productivity. Proposes a diagnostic tool applicable to institutional IT governance., pp. 301–328. DOI: 10.2753/MIS0742-1222240109. URL: https://doi.org/10.2753/MIS0742-1222240109.

[47] T. S. Ragu-Nathan, Monideepa Tarafdar, Bhanu S. Ragu-Nathan, and Qiang Tu. "The Consequences of Technostress for End Users in Organizations: Conceptual Development and Empirical Validation". In: *Information Systems Research* 19.4 (2008). Last consulted 15 February 2026. Validated measurement instruments for technostress creators and inhibitors. Highly relevant to universities seeking to assess and mitigate the negative effects of IT system deployments on staff well-being and retention., pp. 417–433. DOI: 10.1287/isre.1070.0165. URL: https://doi.org/10.1287/isre.1070.0165.

[48] Brett T. Litz, Nathan Stein, Eileen Delaney, Leslie Lebowitz, William P. Nash, Caroline Silva, and Shira Maguen. "Moral Injury and Moral Repair in War Veterans: A Preliminary Model and Intervention Strategy". In: *Clinical Psychology Review* 29.8 (2009). Last consulted 15 February 2026. The concept of moral injury has broader relevance to academic governance as it provides a framework for understanding psychological harm caused by institutional decisions that force individuals to act against their professional or ethical values., pp. 695–706. DOI: 10.1016/j.cpr.2009.07.003. URL: https://doi.org/10.1016/j.cpr.2009.07.003.

[49] Victoria Williamson, Sharon A. M. Stevelink, and Neil Greenberg. "Occupational Moral Injury and Mental Health: Systematic Review and Meta-analysis". In: *British Journal of Psychiatry* 212.6 (2018). Last consulted 15 February 2026. Relevant to academic governance: demonstrates that organizational environments which compel employees to act against their ethical principles can produce measurable psychological harm, informing how universities should design management and decision-making structures., pp. 339–346. DOI: 10.1192/bjp.2018.55. URL: https://doi.org/10.1192/bjp.2018.55.

[50] Paul Hanna, Mark Erickson, and Carl Walker. "UK Higher Education Staff Experiences of Moral Injury during the COVID-19 Pandemic". In: *Higher Education* 86 (2023). Last consulted 15 February 2026. Directly relevant to academic governance: demonstrates how top-down IT and policy decisions in universities can inflict psychological harm on staff when those decisions conflict with professional values and duty of care., pp. 985–1002. DOI: 10.1007/s10734-022-00956-z. URL: https://link.springer.com/article/10.1007/s10734-022-00956-z.

[51] Sophos. *The State of Ransomware in Education 2025*. Sophos. Explores the technical and organizational root causes of attacks, encryption rates, ransom demands, and the human impact on security teams. Critical resource for university IT leaders seeking to understand vulnerability patterns and develop institutional defenses against increasingly sophisticated ransomware threats targeting the education sector. 2025. URL: https://www.sophos.com/en-us/whitepaper/state-of-ransomware-in-education.

[52] NIST. *Guide to a Secure Enterprise Network Landscape*. Tech. rep. SP 800-215. For university IT infrastructure, this resource is directly relevant as academic institutions increasingly adopt distributed cloud resources and remote access models, making zero-trust security frameworks critical for protecting sensitive research data and institutional systems. National Institute of Standards and Technology, 2021. URL: https://csrc.nist.gov/pubs/sp/800/215/final.

[53] *Directive (UE) 2022/2555 du Parlement européen et du Conseil concernant des mesures destinées à assurer un niveau élevé commun de cybersécurité dans l'ensemble de l'Union (NIS2)*. Universities operating data centers, cloud services, or critical research networks may fall within the directive's scope, requiring them to structure cybersecurity governance and risk management in compliance with its provisions. 2022. URL: https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32022L2555.

[54] EDPB. *Guidelines on Security of Processing under GDPR*. European Data Protection Board. The EDPB page is a filterable directory for guidelines, recommendations, and enforcement decisions related to GDPR Article 32 on the security of personal data processing. It serves as a hub for guidance documents that help organizations understand and implement appropriate technical and organizational measures to protect personal data. For universities handling research data, student records, and employee information, these guidelines are essential for establishing compliant data security policies and cybersecurity obligations under EU law. URL: https://www.edpb.europa.eu/gdpr-articles/article-32-security-processing_en.

[55] ENISA. *Risk-Based Approach to Data Processing Security*. European Union Agency for Cybersecurity. Although originally targeting SMEs, the guidelines are broadly applicable to any organization subject to GDPR requirements. For universities managing sensitive research and student data, it provides actionable guidance for developing appropriate security measures that balance risk mitigation with operational constraints. URL: https://www.enisa.europa.eu/publications/guidelines-for-smes-on-the-security-of-personal-data-processing.

[56] IBM Security and Ponemon Institute. *Cost of a Data Breach Report 2024*. Tech. rep. Global all-industry average; the education sector sits below this figure. IBM Security, 2024. URL: https://www.ibm.com/reports/data-breach.

[57] EDUCAUSE. *The EDUCAUSE Information Security Almanac*. EDUCAUSE, April 2019 (two-page almanac derived from the Core Data Service). Data are derived from the 2018 EDUCAUSE Core Data Service (US institutions). The 3.6% figure is the security share of CENTRAL IT spending, identity and access management included. Replaces the former entry educause-spending, which attributed the figure to a 2024 almanac with FY2022–23 data (corrected 3 November 2026). 2019. URL: https://er.educause.edu/-/media/files/library/2019/4/infosecalmanac19.pdf.

[58] Gartner. *Forecasts for Information Security and Risk-Management Spending*. Gartner Newsroom. Cross-industry benchmark context: Gartner IT Key Metrics data report security spend varying roughly between 1% and 13% of the IT budget depending on context, with cross-industry averages in the mid single digits (5.7% of IT spend in 2019, per Gartner data as reported by Cybersecurity Dive, Oct 2020). Earlier versions of this entry carried an unverified 8–15% range; removed June 2026. 2024. URL: https://www.gartner.com/en/newsroom/press-releases/2024-08-28-gartner-forecasts-global-information-security-spending-to-grow-15-percent-in-2025.